Задание 1. Работа с OVAL-файлами

Часть 1. Структурный анализ

Перечислите основные типы XML-элементов и опишите назначение каждого в 2-3 предложениях. Для каждого типа приведите один конкретный пример из файла.

Основные типы XML-элементов:

Definition

- **Назначение:** это главное правило (определение), по которому сканер проверяет систему на уязвимость. Объединяет логические правила проверки(criteria) и метаданные (metadata), которые предоставляют дополнительную информацию.
- **Пример из файла:**

```
<definition class="patch" id="oval:com.redhat.rhba:def:20191992" version="637">
  <metadata> ... </metadata>
  <criteria operator="OR"> ... </criteria>
</definition>
```

Metadata

- **Назначение:** Каждый definition сопровождается набором метаданных, содержащих описательный текст о бюллетене вендора, его названии, составе, метрики (оценка, уровень) уязвимостей и набор cpe для уязвимого ПО.
- **Пример из файла:**

```
<metadata>
  <title>RHBA-2019:1992: cloud-init bug fix and enhancement update (Moderate)</title>
  <affected family="unix">
   <platform>Red Hat Enterprise Linux 8</platform>
  </affected>
  <reference ref_id="RHBA-2019:1992" ref_url="https://access.redhat.com/errata/RHBA-2019:1992"
source="RHSA"/>
  <reference ref_id="CVE-2019-0816" ref_url="https://access.redhat.com/security/cve/CVE-2019-
0816" source="CVE"/>
  <description>The cloud-init packages provide a set of init scripts for cloud
instances….</description>
  <advisory from="secalert@redhat.com">
   <severity>Moderate</severity>
   <rights>Copyright 2019 Red Hat, Inc.</rights>
   <issued date="2019-07-30"/>
   <updated date="2019-07-30"/>
   <cve cvss3="5.4/CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N" cwe="CWE-285"
href="https://access.redhat.com/security/cve/CVE-2019-0816" impact="moderate"
public="20190305">CVE-2019-0816</cve>
   <bugzilla href="https://bugzilla.redhat.com/1680165" id="1680165">cloud-init: extra ssh
keys added to authorized_keys on the Azure platform</bugzilla>
   <affected_cpe_list>…. </affected_cpe_list>
  </advisory>
 </metadata>
```

Criteria

- **Назначение:** формирует логическую структуру условий проверки внутри определения с использованием операторов AND, OR. Элемент может быть вложенным, что позволяет выстраивать сложные условия (например: «ОС является RHEL 8 AND (Пакет А уязвим OR Пакет Б уязвим)»). Может группировать другие criteria и одиночные проверки criterion.
- **Пример из файла:**

```
<criteria operator="OR">
  <criterion comment="Red Hat Enterprise Linux must be installed"
test_ref="oval:com.redhat.rhba:tst:20191992005"/>
  <criteria operator="AND">
   <criterion comment="cloud-init is earlier than 0:18.5-1.el8.4"
test_ref="oval:com.redhat.rhba:tst:20191992001"/>
   <criterion comment="cloud-init is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhba:tst:20191992002"/>
   <criteria operator="OR">
    <criterion comment="Red Hat Enterprise Linux 8 is installed"
test_ref="oval:com.redhat.rhba:tst:20191992003"/>
    <criterion comment="Red Hat CoreOS 4 is installed"
test_ref="oval:com.redhat.rhba:tst:20191992004"/>
   </criteria>
  </criteria>
 </criteria>
```

Criterion

- **Назначение:** является одиночной проверкой логического дерева критериев и ссылается на конкретный OVAL-тест через атрибут test_ref. Содержит поясняющий комментарий (comment), описывающий суть конкретной проверки простым языком.
- **Пример из файла:**

```
<criterion comment="cloud-init is earlier than 0:18.5-1.el8.4"
test_ref="oval:com.redhat.rhba:tst:20191992001"/>
```

Test

- **Назначение:** выполняет проверку конкретного свойства системы путем сопоставления собранных данных с требуемыми параметрами. Связывает между собой конкретный объект системы (object_ref) и требуемое состояние (state_ref) и задает условия их проверки (check). Результат выполнения теста определяет истинность ссылающегося на него критерия.

Все тесты описываются в секции tests. В oval-файле используются несколько типов тестов:

- `rpminfo_test` – Тесты для версий RPM-пакетов
- `rpmverifyfile_test` – Тесты для файлов, принадлежащих RPM-пакетам
- `textfilecontent54_test` – Тесты для текстовых файлов

Пример сопоставления из схемы OVAL (в файле представлена ссылка на него):

В criterion используется ссылка `test_ref="oval:com.redhat.rhba:tst:20191992001"`, которая в соответствующей секции `<tests>` OVAL-файла описывается элементом:

- **Пример из файла:**

```
<red-def:rpminfo_test id="oval:com.redhat.rhba:tst:20191992001" check="at least one"
comment="cloud-init is earlier than 0:18.5-1.el8.4" version="1">
  <red-def:object object_ref="oval:com.redhat.rhba:obj:20191992001"/>
  <red-def:state state_ref="oval:com.redhat.rhba:ste:20191992001"/>
</red-def:rpminfo_test>
```

Object

- **Назначение:** описывает реальную часть системы, которую нужно найти. Это может быть файл, RPM-пакет. Объект только указывает, что именно нужно искать, но сам никаких проверок значений не делает.

Все объекты описываются в секции objects. В oval-файле используются несколько типов объектов:

- `rpminfo_object` – Пакет rpm по имени
- `rpmverifyfile_object` – Проверка целостности и подлинности файлов, установленных из RPM-пакетов.
- `textfilecontent54_object` - Поиск и извлечение строк (или блоков текста) из произвольных текстовых файлов с помощью регулярных выражений.
- **Пример из файла:** тут объектом выступает пакет cloud-init

```
<red-def:rpminfo_object id="oval:com.redhat.rhba:obj:20191992001" version="1">
  <red-def:name>cloud-init</red-def:name>
</red-def:rpminfo_object>
```

State

- **Назначение:** задает значение, с которым нужно сравнить найденный объект и правило сравнения(operation). Если реальные данные объекта совпадают с этим шаблоном, условие считается выполненным.

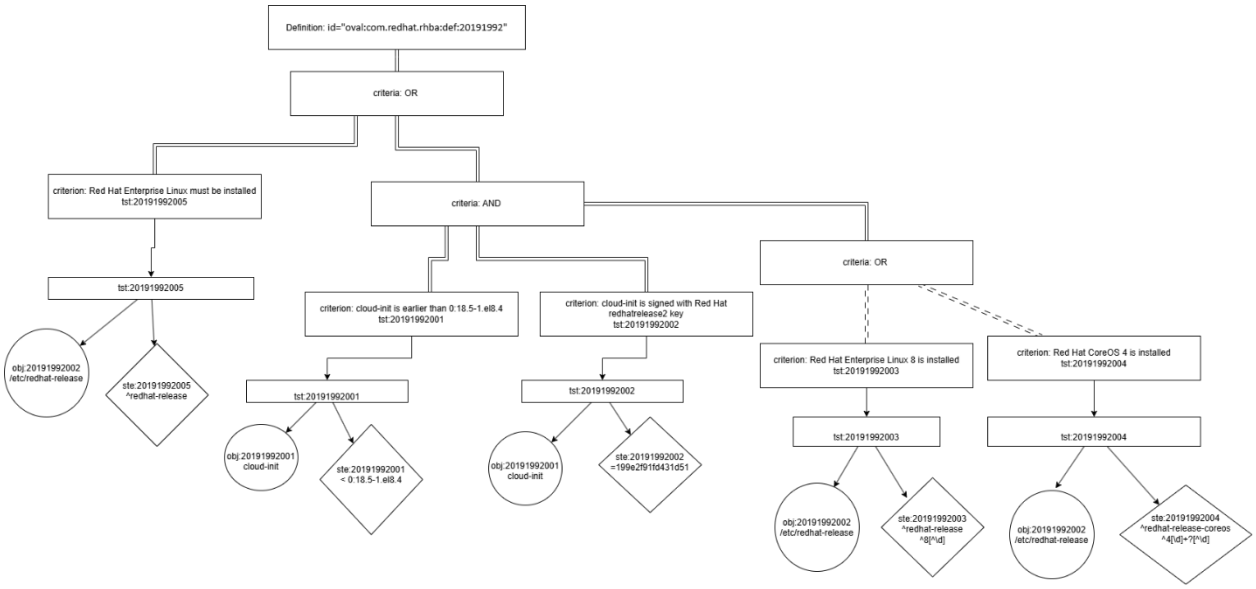
Все состояния описываются в секции states. В oval-файле используются несколько типов состояний:

- `rpminfo_state` – Состояние проверяет значения версий пакета
- `rpmverifyfile_state` - Состояние проверяет результаты верификации файлов.
- `textfilecontent54_state` - Состояние сравнивает значение, захваченное регулярным выражением, со строкой или числом (например, operation="equals", operation="pattern match")
- **Пример из файла.** Например, здесь указывается: «версия пакета должна быть строго меньше 18.5».

```
<red-def:rpminfo_state id="oval:com.redhat.rhba:ste:20191992001" version="1">
  <red-def:evr datatype="evr_string" operation="less than">0:18.5-1.el8.4</red-
def:evr>
</red-def:rpminfo_state>
```

Изобразите цепочку зависимостей в виде схемы для одной конкретной уязвимости (патча) в виде схемы.

Ниже представлена цепочка зависимостей для `id="oval:com.redhat.rhba:def:20191992"` RHBA-2019:1992: cloud-init bug fix and enhancement update (Moderate)



Текстовое описание логики выполнения:

- **Корневой оператор OR:**
  - Либо истинно предварительное требование: «Red Hat Enterprise Linux must be installed» (tst:20191992005).
  - Либо выполняется вложенный блок AND.
- **Блок AND (все три условия должны быть истинными):**
  - **Уязвимая версия:** Пакет cloud-init ниже версии 0:18.5-1.el8.4 (tst:20191992001).
  - **Подлинность пакета:** Пакет cloud-init подписан официальным ключом Red Hat redhatrelease2 (tst:20191992002).
  - **Платформа (вложенный OR):** Установлена ОС либо Red Hat Enterprise Linux 8 (tst:20191992003), либо Red Hat CoreOS 4 (tst:20191992004).

Детализация цепочек «Критерий → Тест → Объект + Состояние»:

- **Проверка версии пакета cloud-init**
  - **Criterion:** comment="cloud-init is earlier than 0:18.5-1.el8.4" (test_ref="...:tst:20191992001").
  - **Test (rpminfo_test):** Связывает объект пакета и состояние версии.
  - **Object (rpminfo_object):** Задает имя искомого пакета в базе RPM — cloud-init.
  - **State (rpminfo_state):** Задает условие сравнения — версия строго меньше (less than) 0:18.5-1.el8.4.

- **Проверка цифровой подписи пакета**
  - **Criterion:** comment="cloud-init is signed with Red Hat redhatrelease2 key" (test_ref="...:tst:20191992002").
  - **Test (rpminfo_test):** Запрашивает атрибуты подписи найденного пакета.
  - **Object (rpminfo_object):** Тот же самый пакет cloud-init.
  - **State (rpminfo_state):** Проверяет совпадение идентификатора ключа (signature_keyid) с отпечатком redhatrelease2.
- **Проверка версии операционной системы (RHEL 8)**
  - **Criterion:** comment="Red Hat Enterprise Linux 8 is installed" (test_ref="...:tst:20191992003").
  - **Test (textfilecontent54_test):** Выполняет чтение системного файла релиза.
  - **Object (textfilecontent54_object):** Путь к файлу /etc/redhat-release и регулярное выражение для поиска строки выпуска.
  - **State (textfilecontent54_state):** шаблонная строка, содержащая версию релиза

Часть 2. Критический анализ проверок

Патч 1: `oval:com.redhat.rhba:def:20193408` (openjpeg2, CVE-2018-6616)

1. Какие проверки входят в условие детектирования

В файле задана следующая структура критериев:

```
<criteria operator="OR">
  <criterion comment="Red Hat Enterprise Linux must be installed"
test_ref="oval:com.redhat.rhba:tst:20191992005"/>
  <criteria operator="AND">
   <criteria operator="OR">
    <criterion comment="Red Hat Enterprise Linux 8 is installed"
test_ref="oval:com.redhat.rhba:tst:20191992003"/>
    <criterion comment="Red Hat CoreOS 4 is installed"
test_ref="oval:com.redhat.rhba:tst:20191992004"/>
   </criteria>
   <criteria operator="OR">
    <criteria operator="AND">
     <criterion comment="openjpeg2 is earlier than 0:2.3.1-1.el8"
test_ref="oval:com.redhat.rhba:tst:20193408001"/>
     <criterion comment="openjpeg2 is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhba:tst:20193408002"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="openjpeg2-devel is earlier than 0:2.3.1-1.el8"
test_ref="oval:com.redhat.rhba:tst:20193408003"/>
     <criterion comment="openjpeg2-devel is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhba:tst:20193408004"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="openjpeg2-devel-docs is earlier than 0:2.3.1-1.el8"
test_ref="oval:com.redhat.rhba:tst:20193408005"/>
     <criterion comment="openjpeg2-devel-docs is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhba:tst:20193408006"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="openjpeg2-tools is earlier than 0:2.3.1-1.el8"
test_ref="oval:com.redhat.rhba:tst:20193408007"/>
     <criterion comment="openjpeg2-tools is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhba:tst:20193408008"/>
    </criteria>
   </criteria>
  </criteria>
 </criteria>
```

- `tst:20191992005`: *«Red Hat Enterprise Linux must be installed»* (базовая проверка ОС RHEL).
- Проверка версии платформы через вложенный `OR`:
  - `tst:20191992003`: *«Red Hat Enterprise Linux 8 is installed»*;
  - `tst:20191992004`: *«Red Hat CoreOS 4 is installed»*.
- Блок `OR` из 4 парных проверок для версий пакетов библиотеки `openjpeg2`:
  - `openjpeg2`: версия раньше `0:2.3.1-1.el8` (`tst:20193408001`) **И** подписан ключом `redhatrelease2` (`tst:20193408002`);
  - `openjpeg2-devel`: версия раньше `0:2.3.1-1.el8` (`tst:20193408003`) **И** подписан ключом `redhatrelease2` (`tst:20193408004`);
  - `openjpeg2-devel-docs`: версия раньше `0:2.3.1-1.el8` (`tst:20193408005`) **И** подписан ключом `redhatrelease2` (`tst:20193408006`);
  - `openjpeg2-tools`: версия раньше `0:2.3.1-1.el8` (`tst:20193408007`) **И** подписан ключом `redhatrelease2` (`tst:20193408008`).

2. Минимальный достаточный набор и избыточные проверки

- **Минимальный набор:**
  1. `tst:20191992003` (или `tst:20191992004`) — подтверждение платформы RHEL 8 / RHCOS 4.
  2. `tst:20193408001` (версия `openjpeg2`) или `tst:20193408007` (версия `openjpeg2-tools`) — проверка исполняемых бинарных компонентов, содержащих уязвимый парсер BMP.
- **Избыточные проверки:**
  - **Корневой `OR` с тестом `tst:20191992005`** (*«RHEL must be installed»*)
  - **Проверка пакета документации `openjpeg2-devel-docs`:** уязвимость CVE-2018-6616 представляет собой DoS при обработке специально сформированного BMP-изображения. Документация не содержит исполняемого кода библиотеки, однако наличие старой версии пакета docs переводит всю проверку в статус истинно.
  - **4 отдельных теста подписи GPG-ключом:** достаточно одного теста для подтверждения вендора вместо проверки каждого отдельного пакета.

3. False Positive и False Negative в нестандартных окружениях

- **Ложноположительные (False Positive):**
  - Если на сервере установлен только пакет с документацией `openjpeg2-devel-docs` старой версии, а сама библиотека `openjpeg2` вообще не установлена, произойдет детект из-за объединения проверок пакетов через оператор `OR`.
- **Ложноотрицательные (False Negative):**
  - Библиотека `openjpeg2` часто используется в составе сторонних утилит. OVAL проверяет исключительно базу данных RPM, поэтому любое использование уязвимой версии библиотеки останется незамеченным.

Патч 2: oval:com.redhat.rhsa:def:20190966 (*firefox*, CVE-2018-18506 и др.)

1. Какие проверки входят в условие детектирования

В файле задана следующая структура критериев:

```
<criteria operator="OR">
  <criterion comment="Red Hat Enterprise Linux must be installed"
test_ref="oval:com.redhat.rhba:tst:20191992005"/>
  <criteria operator="AND">
   <criterion comment="firefox is earlier than 0:60.6.1-1.el8"
test_ref="oval:com.redhat.rhsa:tst:20190966001"/>
   <criterion comment="firefox is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20190966002"/>
   <criteria operator="OR">
    <criterion comment="Red Hat Enterprise Linux 8 is installed"
test_ref="oval:com.redhat.rhba:tst:20191992003"/>
    <criterion comment="Red Hat CoreOS 4 is installed"
test_ref="oval:com.redhat.rhba:tst:20191992004"/>
   </criteria>
  </criteria>
 </criteria>
```

- `tst:20191992005`: *«Red Hat Enterprise Linux must be installed»* (базовая проверка ОС RHEL).
- Проверка версии и подписи пакета через вложенный `and`:
  - `tst:20190966001`: *« firefox is earlier than 0:60.6.1-1.el8»*;
  - `tst:20190966002`: *« firefox is signed with Red Hat redhatrelease2 key»*;
- Проверка версии платформы через вложенный `OR`:
  - `tst:20191992003`: *«Red Hat Enterprise Linux 8 is installed»*;
  - `tst:20191992004`: *«Red Hat CoreOS 4 is installed»*.

2. Минимальный достаточный набор и избыточные проверки

- **Минимальный набор:**
  1. `tst:20191992003` (или `tst:20191992004`) — подтверждение платформы RHEL 8 / RHCOS 4.
  2. `tst:20190966001` — версия установленного пакета `firefox` меньше `0:60.6.1-1.el8`.
- **Избыточные проверки:**
  - **Корневой `OR` с тестом `tst:20191992005`** (*«RHEL must be installed»*)

3. False Positive и False Negative в нестандартных окружениях

- **Ложноположительные (False Positive):**
  - **Установки на серверах без gui:** на серверных инсталляциях RHEL графический интерфейс отсутствует, но пакет `firefox` мог быть случайно установлен зависимостями или оставлен неиспользуемым. Если браузер физически не запускается пользователем, вектор эксплуатации через взаимодействие с пользователем не реализуем(CVE-2019-9810, CVE-2019-9813), однако будет детект этих уязвимостей.
- **Ложноотрицательные (False Negative):**
  - Браузер Firefox можно собрать из исходников или запустить внутри Docker-контейнера. Проверки смотрят только в базу RPM-пакетов, поэтому использование уязвимого Firefox вне RPM-менеджера обнаружено не будет.

Патч 3: `oval:com.redhat.rhsa:def:20190980` (*httpd:2.4*, CVE-2019-0211, CVE-2019-0215)

1. Какие проверки входят в условие детектирования

В файле задана следующая структура критериев:

```
<criteria operator="OR">
  <criterion comment="Red Hat Enterprise Linux must be installed" test_ref="oval:com.redhat.rhba:tst:20191992005"/>
  <criteria operator="AND">
   <criteria operator="OR">
    <criterion comment="Red Hat Enterprise Linux 8 is installed" test_ref="oval:com.redhat.rhba:tst:20191992003"/>
    <criterion comment="Red Hat CoreOS 4 is installed" test_ref="oval:com.redhat.rhba:tst:20191992004"/>
   </criteria>
   <criteria operator="OR">
    <criteria operator="AND">
     <criterion comment="Module httpd:2.4 is enabled" test_ref="oval:com.redhat.rhsa:tst:20190980023"/>
     <criteria operator="OR">
      <criteria operator="AND">
       <criterion comment="httpd is earlier than 0:2.4.37-11.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980001"/>
       <criterion comment="httpd is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980002"/>
      </criteria>
      <criteria operator="AND">
       <criterion comment="httpd-devel is earlier than 0:2.4.37-11.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980003"/>
       <criterion comment="httpd-devel is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980004"/>
      </criteria>
      <criteria operator="AND">
       <criterion comment="httpd-filesystem is earlier than 0:2.4.37-11.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980005"/>
       <criterion comment="httpd-filesystem is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980006"/>
      </criteria>
      <criteria operator="AND">
       <criterion comment="httpd-manual is earlier than 0:2.4.37-11.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980007"/>
       <criterion comment="httpd-manual is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980008"/>
      </criteria>
      <criteria operator="AND">
       <criterion comment="httpd-tools is earlier than 0:2.4.37-11.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980009"/>
       <criterion comment="httpd-tools is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980010"/>
      </criteria>
      <criteria operator="AND">
       <criterion comment="mod_http2 is earlier than 0:1.11.3-2.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980011"/>
       <criterion comment="mod_http2 is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980012"/>
      </criteria>
      <criteria operator="AND">
       <criterion comment="mod_ldap is earlier than 0:2.4.37-11.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980013"/>
       <criterion comment="mod_ldap is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980014"/>
      </criteria>
      <criteria operator="AND">
       <criterion comment="mod_md is earlier than 0:2.4.37-11.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980015"/>
       <criterion comment="mod_md is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980016"/>
      </criteria>
      <criteria operator="AND">
       <criterion comment="mod_proxy_html is earlier than 1:2.4.37-11.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980017"/>
       <criterion comment="mod_proxy_html is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980018"/>
      </criteria>
      <criteria operator="AND">
       <criterion comment="mod_session is earlier than 0:2.4.37-11.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980019"/>
       <criterion comment="mod_session is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980020"/>
      </criteria>
      <criteria operator="AND">
       <criterion comment="mod_ssl is earlier than 1:2.4.37-11.module+el8.0.0+2969+90015743"
test_ref="oval:com.redhat.rhsa:tst:20190980021"/>
       <criterion comment="mod_ssl is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20190980022"/>
      </criteria>
     </criteria>
    </criteria>
   </criteria>
  </criteria>
 </criteria>
```

- `tst:20191992005`: *«Red Hat Enterprise Linux must be installed»* (базовая проверка ОС RHEL).

• Проверка версии платформы: RHEL 8 (`tst:20191992003`) или CoreOS 4 (`tst:20191992004`).

- **Проверка модульного стрима:** `tst:20190980023` — ***«Module httpd:2.4 is enabled»***.

- Блок `OR` из 11 парных проверок на версию и подпись для компонентов веб-сервера Apache:

  - `httpd`: версией раньше `0:2.4.37-11.module+el8.0.0+2969+90015743` (`tst:...001`) + подпись `redhatrelease2` (`tst:...002`);
  - `httpd-devel`, `httpd-filesystem`, `httpd-manual`, `httpd-tools`;
  - Модули расширений: `mod_http2`, `mod_ldap`, `mod_md`, `mod_proxy_html`, `mod_session`, `mod_ssl` (каждый со своей парой тестов на версию и подпись).

2. Минимальный достаточный набор и избыточные проверки

- **Минимальный набор:**
  1. `tst:20191992003` (или `tst:20191992004`) — подтверждение платформы RHEL 8 / RHCOS 4.
  2. Проверка включения модуля: `tst:20190980023` (*«Module httpd:2.4 is enabled»*).
  3. Проверка версии основного исполняемого демона: `tst:20190980001` (`httpd is earlier than...`) или конкретного уязвимого модуля (например, `mod_ssl`, где присутствует CVE-2019-0215).
- **Избыточные проверки:**
  - **Корневой `OR` с тестом `tst:20191992005`** (*«RHEL must be installed»*)
  - Проверка пакетов документации и вспомогательных утилит: `httpd-manual` и `httpd-filesystem` не содержат исполняемых файлов веб-сервера для эксплуатации уязвимостей, но их наличие даст успешный детект.
  - 11 тестов проверки ключа подписи (`redhatrelease2`) дублируются для каждого субпакета по отдельности.

3. False Positive и False Negative в нестандартных окружениях

- **Ложноположительные (False Positive):**
  - Если на сервере установлен только утилитный пакет `httpd-tools` старой версии, а сам веб-сервер `httpd` и модуль `mod_ssl` не установлены и трафик не принимают, всё равно произойдет детект из-за оператора `OR` в списке пакетов.
- **Ложноотрицательные (False Negative):**
  - Веб-сервер уязвимой версии может быть поднят в докер-контейнере и отсутствовать в виде пакета, что приведет к отсутствию уязвимостей.
  - Apache может быть установлен из стороннего стека, где бинарные файлы имеют другое название пакета. А проверка ищет точное имя пакета, пакет с префиксом не сопоставляется с объектом `rpminfo_object`, проверка не срабатывает, а уязвимый веб-сервер остаётся незамеченным.

Патч 4: `oval:com.redhat.rhsa:def:20191714` (bind, CVE-2019-6471)

1. *Какие проверки входят в условие детектирования?*

```
<criteria operator="OR">
  <criterion comment="Red Hat Enterprise Linux must be installed" test_ref="oval:com.redhat.rhba:tst:20191992005"/>
  <criteria operator="AND">
   <criteria operator="OR">
    <criterion comment="Red Hat Enterprise Linux 8 is installed" test_ref="oval:com.redhat.rhba:tst:20191992003"/>
    <criterion comment="Red Hat CoreOS 4 is installed" test_ref="oval:com.redhat.rhba:tst:20191992004"/>
   </criteria>
   <criteria operator="OR">
    <criteria operator="AND">
     <criterion comment="bind is earlier than 32:9.11.4-17.P2.el8_0.1" test_ref="oval:com.redhat.rhsa:tst:20191714001"/>
     <criterion comment="bind is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20191145002"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-chroot is earlier than 32:9.11.4-17.P2.el8_0.1" test_ref="oval:com.redhat.rhsa:tst:20191714003"/>
     <criterion comment="bind-chroot is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145004"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-devel is earlier than 32:9.11.4-17.P2.el8_0.1" test_ref="oval:com.redhat.rhsa:tst:20191714005"/>
     <criterion comment="bind-devel is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145006"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-export-devel is earlier than 32:9.11.4-17.P2.el8_0.1"
test_ref="oval:com.redhat.rhsa:tst:20191714007"/>
     <criterion comment="bind-export-devel is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145008"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-export-libs is earlier than 32:9.11.4-17.P2.el8_0.1"
test_ref="oval:com.redhat.rhsa:tst:20191714009"/>
     <criterion comment="bind-export-libs is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145010"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-libs is earlier than 32:9.11.4-17.P2.el8_0.1" test_ref="oval:com.redhat.rhsa:tst:20191714011"/>
     <criterion comment="bind-libs is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20191145012"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-libs-lite is earlier than 32:9.11.4-17.P2.el8_0.1"
test_ref="oval:com.redhat.rhsa:tst:20191714013"/>
     <criterion comment="bind-libs-lite is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145014"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-license is earlier than 32:9.11.4-17.P2.el8_0.1"
test_ref="oval:com.redhat.rhsa:tst:20191714015"/>
     <criterion comment="bind-license is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145016"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-lite-devel is earlier than 32:9.11.4-17.P2.el8_0.1"
test_ref="oval:com.redhat.rhsa:tst:20191714017"/>
     <criterion comment="bind-lite-devel is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145018"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-pkcs11 is earlier than 32:9.11.4-17.P2.el8_0.1" test_ref="oval:com.redhat.rhsa:tst:20191714019"/>
     <criterion comment="bind-pkcs11 is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145020"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-pkcs11-devel is earlier than 32:9.11.4-17.P2.el8_0.1"
test_ref="oval:com.redhat.rhsa:tst:20191714021"/>
     <criterion comment="bind-pkcs11-devel is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145022"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-pkcs11-libs is earlier than 32:9.11.4-17.P2.el8_0.1"
test_ref="oval:com.redhat.rhsa:tst:20191714023"/>
     <criterion comment="bind-pkcs11-libs is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145024"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-pkcs11-utils is earlier than 32:9.11.4-17.P2.el8_0.1"
test_ref="oval:com.redhat.rhsa:tst:20191714025"/>
     <criterion comment="bind-pkcs11-utils is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145026"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-sdb is earlier than 32:9.11.4-17.P2.el8_0.1" test_ref="oval:com.redhat.rhsa:tst:20191714027"/>
     <criterion comment="bind-sdb is signed with Red Hat redhatrelease2 key" test_ref="oval:com.redhat.rhsa:tst:20191145028"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-sdb-chroot is earlier than 32:9.11.4-17.P2.el8_0.1"
test_ref="oval:com.redhat.rhsa:tst:20191714029"/>
     <criterion comment="bind-sdb-chroot is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145030"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="bind-utils is earlier than 32:9.11.4-17.P2.el8_0.1" test_ref="oval:com.redhat.rhsa:tst:20191714031"/>
     <criterion comment="bind-utils is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145032"/>
    </criteria>
    <criteria operator="AND">
     <criterion comment="python3-bind is earlier than 32:9.11.4-17.P2.el8_0.1"
test_ref="oval:com.redhat.rhsa:tst:20191714033"/>
```

```
     <criterion comment="python3-bind is signed with Red Hat redhatrelease2 key"
test_ref="oval:com.redhat.rhsa:tst:20191145034"/>
    </criteria>
   </criteria>
  </criteria>
 </criteria>
```

Базовое системное требование: `tst:20191992005` (*«Red Hat Enterprise Linux must be installed»*).

Версия операционной системы (блок OR):

- `tst:20191992003`: *«Red Hat Enterprise Linux 8 is installed»*;
- `tst:20191992004`: *«Red Hat CoreOS 4 is installed»*.

Пакеты экосистемы BIND (блок OR из парных проверок AND):

Для каждого пакета проверяется связка:

«версия раньше 32:9.11.4-17.P2.el8_0.1» **И** *«подписан официальным ключом Red Hat redhatrelease2»*.

В список входят:

- Сам DNS-сервер: `bind`;
- Клиентские утилиты и диагностика, документация: `bind-utils`, `bind-libs-lite`, `bind-license`;
- Разделяемые библиотеки: `bind-libs`, `bind-export-libs`, `bind-export-devel`, `bind-devel`;
- Вспомогательные модули: `bind-chroot`, `bind-pkcs11`, `bind-pkcs11-utils`, `bind-pkcs11-libs`, `bind-sdb`, `python3-bind`.

2. Минимальный достаточный набор и избыточные проверки

- **Минимальный набор проверок:**
  1. `tst:20191992003` — подтверждение платформы RHEL 8.
  2. `bind is earlier than 32:9.11.4-17.P2.el8_0.1` — проверка версии основного пакета `bind` (содержащего исполняемый демон `named`). Уязвимость CVE-2019-6471 представляет собой DoS при обработке определённых DNS-ответов демоном `named`.
- **Избыточные и дублирующие проверки:**
  - **Корневой оператор OR** с тестом `tst:20191992005` (*«RHEL must be installed»*) традиционно избыточен и поглощается проверкой RHEL 8.
  - **Пакеты клиентских утилит и разработки:** `bind-utils`, `bind-devel`, `bind-export-devel`, `bind-license` не принимают входящие сетевые DNS-запросы и не являются сервером `named`. Но их наличие переводит всё правило в статус `true` из-за оператора `OR`.
  - **Парное дублирование проверки GPG-подписи:** проверка ключа `redhatrelease2` дублируется для каждого из более чем 10 субпакетов, хотя все они собираются из единого исходного пакета SRPM `bind`.

3. False Positive и False Negative в нестандартных окружениях

- **Ложноположительные (False Positive):**
  - **Клиентские и офисные машины (только `bind-utils`):** пакет `bind-utils` (содержащий команды `dig` и `host`) установлен практически на каждом сервере. Сам сервер BIND (`named`) при этом выключен или не установлен вовсе. Детект пометит хост как уязвимый только из-за присутствия этого пакета.
  - **Сервис остановлен (Service Disabled):** пакет `bind` может быть установлен, но служба `systemctl is-active named` возвращает `inactive`. Сетевой порт 53 закрыт, вектор эксплуатации отсутствует, однако из-за установленного пакета будет детект.
- **Ложноотрицательные (False Negative):**
  - **Запуск без перезапуска демона:** пакет `bind` обновлён, но команда `systemctl reload- или -restart named` не выполнилась. В оперативной памяти продолжает функционировать процесс со старой уязвимой библиотекой `libisc`.

Часть 3. Упрощение формата

Для упрощённого формата предлагается использовать JSON.

Основные преимущества JSON:

- **Простота восприятия:** формат построен на базе понятных пар «ключ — значение» и стандартных массивов, благодаря чему его структура легко считывается человеком.
- **Легковесность и скорость:** в отличие от XML, в JSON отсутствуют громоздкие закрывающие теги, что существенно снижает итоговый объём данных.
- **Универсальная структура:** поддержка базовых типов (строки, числа, логические значения, массивы, объекты и `null`) позволяет наглядно описывать сложные иерархические и вложенные структуры.

Ниже представлен альтернативный формат описания уязвимости (на примере разобранного бюллетеня RHBA-2019:1992 для cloud-init) и подробный комментарий по оптимизации.

```
{
  "id": "RHBA-2019:1992",
  "title": "RHBA-2019:1992: cloud-init bug fix and enhancement update (Moderate)",
  "cves": [
      {
        "cve_id": "CVE-2019-0816",
        "cvss_score": "5.4",
        "cvss_vector": "CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N"
      }
    ],
  "severity": "Moderate",
  "affected_platforms": [
    "RHEL-8",
    "RHCOS-4"
  ],
  "detection": {
    "type": "rpm",
    "operator": "AND",
    "rules": [
      {
        "package": "cloud-init",
        "fixed_version": "0:18.5-1.el8.4",
        "operator": "less_than",
        "signed_by": "redhatrelease2"
      }
    ]
  }
}
```

Какие поля и сущности были убраны и почему?

1. Убрано разделение на 4 секции (`criterion`, `test`, `object`, `state`):
    - *Почему:* Некоторые тесты, объекты похожи друг на друга(например, проверки подписи), но имеют уникальный id, что раздувает файл. В новом формате имя пакета, безопасная версия и условие проверки объединены в **одно правило (`rule`)**, что сразу дает понимание.
2. Устранены числовые ID и ссылки (`test_ref`, `object_ref`, `state_ref`):
    - *Почему:* Чтобы посмотреть объект и состояние из теста `oval:com.redhat.rhba:tst:20191992001` необходимо найти эти сущности

по ссылкам, что заставляет человека и скрипт постоянно прыгать по разным секциям файла, а потом возвращаться обратно к исходному тесту.

3. **Исключены избыточные проверки ОС общего характера:**
   - *Почему:* В файле присутствуют тесты вроде `Red Hat Enterprise Linux must be installed` (`tst:...005`), объединённые через корневой `OR`. Его можно заменить коротким массивом `affected_platforms: ["RHEL-8"]`.
4. Убраны дублирующиеся тесты цифровой подписи (GPG):
   - *Почему:* В OVAL на каждый пакет создается отдельный тест `... is signed with Red Hat key`. В JSON-формате ключ либо задаётся глобально для вендора по умолчанию, либо указывается коротким атрибутом `"signed_by": "redhatrelease2"`.
5. Очищены второстепенные метаданные:
   - *Почему:* Блоки `bugzilla`, `advisory rights`, длинные списки `affected_cpe_list`, ссылки на внешние errata и полные описания занимают до 70% метаданных. Для задачи **детектирования** они не нужны. Оставлены только ключевые метрики для приоритизации: `id`, `cve`, `cvss_score`, `cvss_vector`, `severity`.

Задание 2. Анализ уязвимостей

Выполнен анализ уязвимостей, опубликованных начиная с **15.09.2026**.

С помощью Python-скрипта из официального фида **CISA KEV** были выгружены все записи за последние 30 дней — суммарно получено **32 уязвимости**.

Для выделения пула потенциально опасных уязвимостей применялись следующие критерии фильтрации:

- **Вид целевого актива:** внешние публичные веб-приложения и сервисы; исключено специализированное сетевое оборудование и телеком-инфраструктура (так как представленные вендоры ушли из России было принято решение их не рассматривать);
- **Распространённость ПО и объём поверхности атаки:** доминирующее на рынке прикладное ПО с широкой базой публичных установок. Проприетарные узкоспециализированные решения и legacy-компоненты исключены.
- **Уровень опасности (Severity):** Critical или High;
- **Вектор атаки (Attack Vector):** сетевой (`AV:N`);
- **Статус эксплуатации (Exploit Code Maturity):** подтверждён факт активной эксплуатации или наличие публичного эксплойта (`E:P` / KEV);
- **Тип воздействия (Impact Type):** `RCE, ACE, DoS, PoE / LPE`.

По результатам применения критериев для дальнейшего анализа была выбрана уязвимость **CVE-2026-87902** (WordPress Core — Remote File Inclusion).

Ниже в таблице представлена выгрузка из фида(зеленым подсвечены уязвимости, опубликованные(по данным с cve.org) за 30 дней, т.к. в выгрузке есть старые уязвимости):

CVE ID	Продукт / ПО	Тип уязвимости	Дата добавления в KEV
CVE-2026-105134	Ahsay AhsayCBS	Command Injection	14.10.2026
CVE-2026-76519	Cisco Secure Email Gateway	Path Traversal	14.10.2026
CVE-2026-105133	Ahsay AhsayCBS	Improper Authentication	14.10.2026
CVE-2026-0322	Palo Alto Networks PAN-OS	Code Injection	14.10.2026
CVE-2026-104935	Ivanti Connect Secure	Auth Bypass by Spoofing	13.10.2026
CVE-2015-5477	ISC BIND	Data Processing Error / DoS	08.10.2026
CVE-2016-3081	Apache Struts	Command Injection (RCE)	08.10.2026
CVE-2023-22894	Strapi Strapi	Cleartext Storage	08.10.2026
CVE-2021-3199	ONLYOFFICE Docs	Path Traversal	08.10.2026
CVE-2015-3306	ProFTPD ProFTPD	Improper Access Control	08.10.2026
CVE-2026-88779	Citrix NetScaler	Buffer Overflow	04.10.2026
CVE-2026-102490	Zammad Helpdesk	Privilege Escalation (LPE)	02.10.2026
CVE-2026-102489	Zammad Helpdesk	Session Fixation	02.10.2026
CVE-2026-104286	Fortinet FortiMail	Path Traversal	01.10.2026
CVE-2026-76504	Cisco Catalyst SD-WAN	Hex Encoding Flaw	30.09.2026
CVE-2026-86950	Apple Products	Out-of-Bounds Write	29.09.2026
CVE-2026-88772	Citrix NetScaler	Buffer Overflow	27.09.2026
CVE-2026-88771	Citrix NetScaler	Input Validation Flaw	27.09.2026
CVE-2026-67279	MikroTik RouterOS	Workflow Enforcement Flaw	25.09.2026
CVE-2026-87902	WordPress Core	Remote File Inclusion (RFI)	25.09.2026
CVE-2026-5430	WSO2 Products	Path Traversal	24.09.2026
CVE-2026-71362	Adobe Commerce / Magento	Incorrect Authorization	24.09.2026
CVE-2026-93952	Arista VeloCloud Orchestrator	Input Validation Flaw	22.09.2026
CVE-2026-94127	F5 BIG-IP APM	Heap Buffer Overflow	22.09.2026
CVE-2026-93616	Check Point Products	Path Traversal	22.09.2026
CVE-2026-85102	Check Point Products	Certificate Validation Flaw	22.09.2026
CVE-2026-7273	Zyxel GS1900 Switches	Stack Buffer Overflow	21.09.2026
CVE-2025-39964	Linux Kernel	Race Condition	18.09.2026
CVE-2026-53266	Linux Kernel	Out-of-Bounds Write	18.09.2026
CVE-2025-39682	Linux Kernel	Exceptional Condition Check	18.09.2026
CVE-2026-76460	Cisco Identity Services Engine	Privileged API Misuse	16.09.2026
CVE-2026-87886	Acronis Backup	Incorrect Permissions	16.09.2026

Среди выявленных прикладных веб-уязвимостей наибольшую опасность с точки зрения масштаба потенциальных атак представляет **CVE-2026-87902 в WordPress Core**.

Выбор обусловлен тремя факторами:

1. **Глобальная распространённость платформы:** WordPress - самая популярная система управления контентом, поэтому площадь атаки обширна.
2. **Критичность дефекта в ядре (Core):** уязвимость затрагивает базовый код системы, а не сторонние плагины или темы, что делает атаку универсальной для непропатченных версий.
3. **Вектор воздействия (RFI):** удалённое включение файлов (Remote File Inclusion) позволяет злоумышленнику добиться произвольного выполнения кода (RCE) на периметровом веб-сервере без предварительной аутентификации.

CVE-2026-87902 : уязвимость удаленного выполнения кода (Remote Code Execution, RCE) в ядре системы управления контентом WordPress

Уровень критичности по оценке CVSS: 8.1

Вектор атаки: сетевой

Подтверждение вендора: Wordpress

Информация об уязвимости

Описание уязвимости:

Неаутентифицированный злоумышленник может отправить специальный запрос к функции get_page_template() для подключения локальных читаемых .php-файлов за пределами директории активной темы. Уязвимость затрагивает WordPress всех версий от 4.7.0 до 7.1.1 (включая ветки до 7.1.2).

Уязвимость представляет собой **неаутентифицированное включение локальных файлов (Unauthenticated LFI)** в функции разрешения шаблонов страниц WordPress (`get_page_template()` в файле `wp-includes/template.php`). Из-за отсутствия надлежащей проверки входных данных (валидации пути) в определенной ветке обработки переменной `pagename` (которая передается из запроса), злоумышленник может передать последовательности обхода каталогов (`../`), заставив систему подключить произвольный локальный `.php`-файл, находящийся за пределами директорий активной темы.

Сама по себе уязвимость гарантирует лишь чтение и выполнение локального PHP-файла, уже присутствующего на диске. Превращение LFI в полноценный RCE зависит от выполнения предварительных условий:

Структура темы: Активная дочерняя или родительская тема должна содержать каталог верхнего уровня, имя которого начинается с префикса `page-` (например, `page-templates`). Под это условие подпадают устаревшие стандартные темы *Twenty Twelve* и *Twenty Fourteen*, а также некоторые популярные сторонние темы, такие как *Neve*, *Hestia* и *Sydney*.

Когда пользователь запрашивает страницу по её slug-имени (параметр `pagename`), движок WordPress ищет подходящий файл шаблона в каталоге активной темы. Логика поиска строится на переборе кандидатов: от наиболее специфичного имени файла к общему (например, `page-{slug}.php`, затем `page.php`).

Опасность возникает, если пользовательский ввод передается в конкатенацию путей **без строгой валидации на выход за пределы корневой папки темы**.

Имя файла строится по шаблону "page-{$pagename-decoded}.php".

Тогда атакующий может передать строку вида templates/../../... , которая при наличии каталога `page-templates`, превратится в валидный путь page-templates/../../..., который ОС обработает как выход вверх по дереву каталогов.

Доступный локальный PHP-файл: На сервере должен существовать выбранный локальный целевой файл с расширением `.php`, доступный для чтения учетной записью веб-сервера. Для этого может использоваться стандартный PEAR-компонент `pearcmd.php` (часто поставляемый с PHP в Docker-контейнерах или типовых конфигурациях cPanel) с включенной директивой `register_argc_argv = On`, которая позволяет параметрам из HTTP-запроса передаваться скрипту в качестве аргументов командной строки.

Статус эксплуатации уязвимости:

Уязвимость была опубликована 22 сентября, в тот же день первые сканирования и попытки фаззинга были зарегистрированы телеметрией Patchstack в **11:49 UTC 22 сентября 2026 г.** В последующие дни сеть CrowdSec зафиксировала лавинообразный рост попыток эксплуатации: свыше 320 000 сигнатурных атак более чем с 30 000 уникальных IP-адресов. Агентство CISA внесло уязвимость в каталог Known Exploited Vulnerabilities (KEV) из-за подтверждённого факта активной массовой эксплуатации in-the-wild 25 сентября. В публичном доступе имеются готовые шаблоны (Nuclei, PoC-скрипты). Злоумышленники при атаке используют обход каталогов (path traversal) для подключения локальных PHP-файлов, такого как pearcmd.php, записывают веб-шелл во временные директории и далее закрепляются в системе с помощью загруженных PHP-скриптов, размещённых на GitHub. Атака позволяет полностью скомпрометировать систему.

Рекомендации по устранению:

Обновить ядро WordPress до версии 7.1.2 или новее.

Возможные митигации:

Удалить файл `pearcmd.php`.

Отключить директиву register_argc_argv в php.ini.

Запретить на веб-сервере создание исполняемых файлов в временных каталогах /tmp и /var/tmp.

Блокировка на WAF запросов, содержащих последовательности Path Traversal(%2e%2e, %252e%252e) в параметре pagename или в теле post-запросов.

Возможные негативные сценарии:

Успешная эксплуатация уязвимости приводит к выполнению произвольного кода (RCE) на периметровом веб-сервере с правами системного пользователя, что далее ведет к полной компрометации системы.